

M 301: Qark (15 pts extra)

What You Need for This Project

- A Debian virtual machine. I used a headless Debian 11 machine.

Purpose

To practice using Qark, an Android vulnerability scanner from LinkedIn.

WARNING: Slow Project

Qark takes about 30 minutes to run. If you don't want to wait, skip this project.

Installing Qark

On your Debian Linux machine, open a Terminal window. Execute these commands:

```
sudo apt update
sudo apt install git unzip python3-pip python3-full default-jdk -y

wget https://github.com/linkedin/qark/archive/refs/heads/master.zip
unzip master.zip

python3 -m venv qark-venv
source qark-venv/bin/activate
pip3 install qark
qark
```

You see a Qark help message, as shown below.

If you see a message saying "qark not found", reboot your Debian machine.

```

sambowne — debian@debian: ~ — ssh debian@192.168.0.245 — 86x30
debian@debian:~$ ./qark-venv/bin/qark
Please pass a source for scanning through either --java or --apk
Usage: qark [OPTIONS]

Options:
  --sdk-path DIRECTORY      Path to the downloaded SDK directory if
                             already downloaded. Only necessary if
                             --exploit-apk is passed. If --exploit-apk is
                             passed and this flag is not passed, QARK will
                             attempt to use the ANDROID_SDK_HOME,
                             ANDROID_HOME, ANDROID_SDK_ROOT environment
                             variables (in that order) for a path.
  --build-path DIRECTORY    Path to place decompiled files and exploit
                             APK. [default: build]
  --debug / --no-debug      Show debugging statements (helpful for
                             issues). [default: no-debug]
  --apk PATH                APK to decompile and run static analysis. If
                             passed, the --java option is not used.
  --java PATH               A directory containing Java code, or a Java
                             file, to run static analysis. If passed, the
                             --apk option is not used.
  --report-type [html|xml|json|csv]
                             Type of report to generate along with
                             terminal output. [default: html]
  --exploit-apk / --no-exploit-apk
                             Create an exploit APK targetting a few
                             vulnerabilities. [default: no-exploit-apk]
  --version                 Show the version and exit.
  --help                    Show this message and exit.
debian@debian:~$

```

Scanning the GenieMD APK with Quark

On Debian, execute these commands:

```

wget https://samsclass.info/128/proj/genie.apk
qark --apk genie.apk

```

Qark takes about 30 minutes to unpack all the code and scan it, ending with the path to a report file, as shown below.

After the report is generated, move it to a more convenient location and name with this command:

```

mv /home/debian/qark-venv/lib/python3.11/site-packages/qark/report/report.html genie.html

```

```

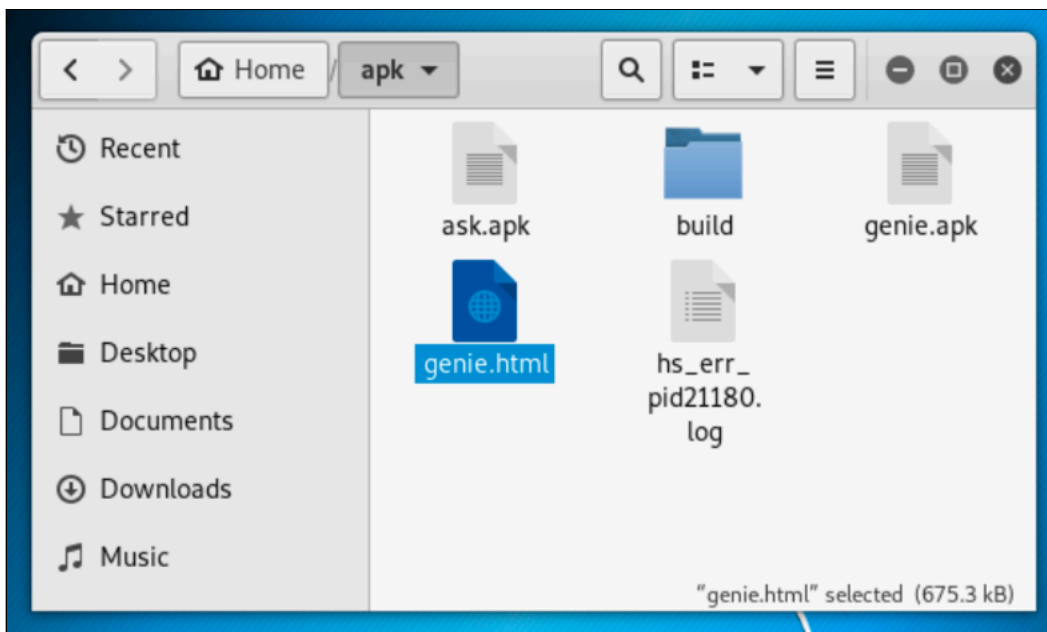
INFO:  Decompiling class repack/org/bouncycastle/asn1/BERTaggedObject
INFO:  ... done
INFO:  Decompiling class repack/org/bouncycastle/asn1/LazyDERSequence
INFO:  ... done
Running scans...
Finish scans...
Writing report...
Finish writing report to /usr/local/lib/python2.7/dist-packages/qark/report/report.html ...
root@kali:~/apk# mv /usr/local/lib/python2.7/dist-packages/qark/report/report.html genie.html

```

Viewing the Report

If you have a Linux machine with a desktop, on your Debian desktop, on the left side, click the folder icon.

Navigate to the **genie.htm** file, as shown below, and double-click it.

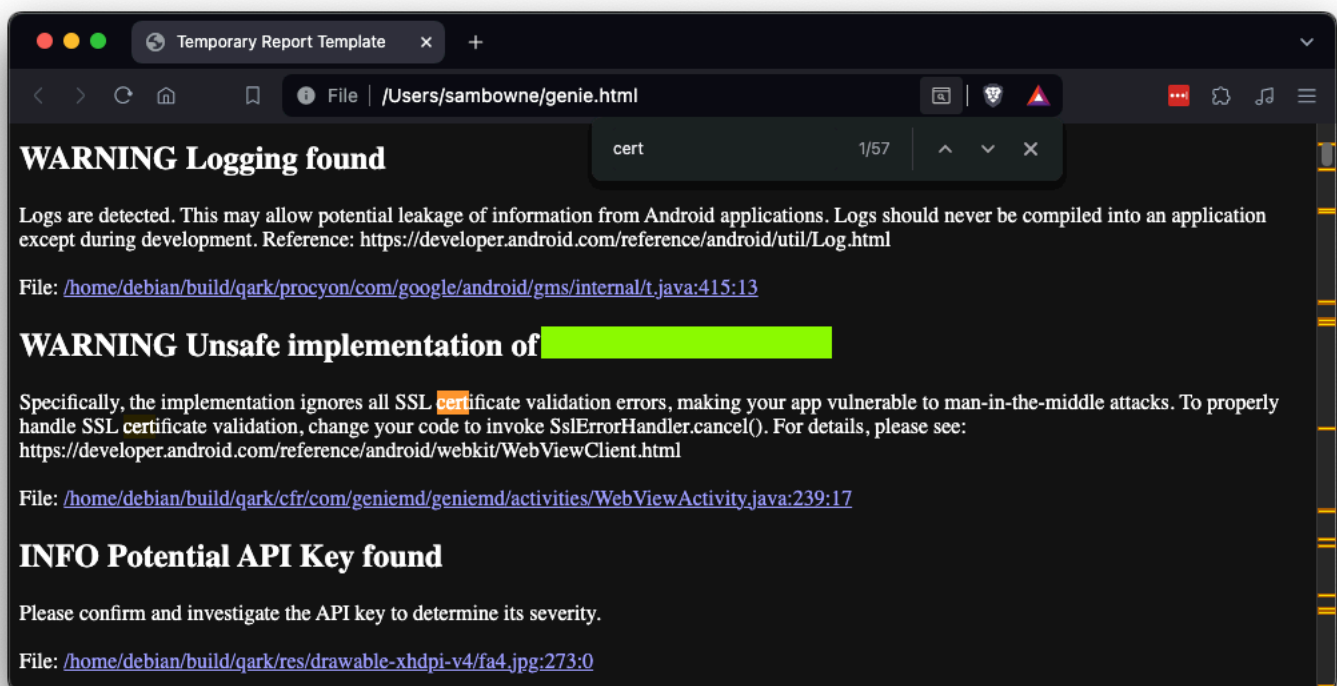


If you are using a headless server, use an scp command like the one below to move the report to your host machine and open it there.

```
scp debian@192.168.0.245:genie.html .
```

The report opens in a Web browser, as shown below.

Type **Ctrl+F** and search for **cert** to find the SSL certificate validation error, as shown below.



M 301: Unsafe implementation (15 pts)

Find the text covered by a green box in the image above. That's the flag.

Sources

[Qark](#)
[Android Penetration Tools Walkthrough Series: QARK](#)

Posted 1-24-19 by Sam Bowne
Converted to a CTF 2-28-19
Install python-pip added 2-19-2020
Changed from Kali to Debian 3-10-2021
Updated to Python 3 and Debian 11 2-19-24
Installation simplified 6-10-25